

Asistente de Ciberseguridad y Compliance con IA

Índice

Contenido

Fase 1 — Diseño del asistente	3
1.1 Problema y usuario	3
1.2 Tecnologías elegidas	3
1.3 Herramienta de orquestación	3
1.4 Gestor documental	3
1.5 Flujo de las 4 capacidades	3
1.6 Diagrama visual del flujo	4
Fase 2 — Base de conocimiento (RAG)	5
2.1 Documentos indexados	5
2.2 Proceso de indexación	5
2.3 Evidencia de funcionamiento del RAG	5
Fase 3 — Construcción del asistente	6
3.1 Capacidad 1 — Análisis de la política de seguridad de MIDTECH	6
3.2 Capacidad 2 — Gap Analysis	7
3.3 Capacidad 3 — Respuestas de auditoría	7
3.4 Capacidad 4 — Propuestas de mejora	9
Fase 4 — Entrega y demostración	11
4.1 Acceso al asistente	11
4.2 Vídeo de demostración	11
4.3 Repositorio GitHub	11
4.4 Canvas de n8n	11
Flujo 1 — Chat con el usuario:	12
Flujo 2 — Indexación de documentos:	12
Anexo — Documentación de prompts	13
Prompt C1 — Análisis de política	13
Prompt C2 — Gap Analysis	13
Prompt C3 — Auditoría	14
Prompt C4 — Propuestas de mejora	14
Reflexión final	16

Fase 1 — Diseño del asistente

1.1 Problema y usuario

MIDTECH S.A. no tiene una forma ágil de comprobar si su política de seguridad cumple con las normativas que le aplican — GDPR, ISO 27001 y ENS. He construido este asistente para que el responsable de seguridad o el DPD pueda hacer preguntas en lenguaje normal y recibir respuestas concretas citando tanto la política interna de la empresa como los artículos o controles normativos correspondientes.

1.2 Tecnologías elegidas

Componente	Tecnología elegida	Por qué la he elegido
LLM	Google Gemini Pro (gemini-pro-latest).	API gratuita, funciona en español y soporta documentos largos
Orquestación	n8n Cloud	Flujos visuales sin código, conectores nativos para Drive y Gemini
Gestor documental	Google Drive	Carpeta compartida con normativa y política de MIDTECH
RAG / Embeddings	Tienda de vectores simple + Gemini Embeddings	Búsqueda semántica por significado
Memoria	Memoria simple n8n	El asistente recuerda el contexto dentro de la misma sesión

1.3 Herramienta de orquestación

He elegido n8n Cloud. Permite construir los flujos de forma visual sin escribir código y tiene conectores nativos para Google Drive y Google Gemini. El despliegue en la nube facilita que el asistente esté accesible desde una URL pública sin necesidad de mantener un servidor propio. La alternativa era Make, pero n8n ofrece más control sobre el flujo del agente de IA y la tienda de vectores está integrada de forma nativa, lo que simplifica mucho la arquitectura RAG.

1.4 Gestor documental

He elegido Google Drive. Los documentos de normativa (GDPR, ISO 27001, ENS) y la política de seguridad de MIDTECH están en una carpeta compartida que n8n puede leer directamente a través del conector oficial de Google Drive, sin necesidad de subir los archivos manualmente cada vez. La alternativa era Notion, pero Google Drive es más directo para gestionar PDFs y la integración con n8n no requiere configuración adicional.

1.5 Flujo de las 4 capacidades

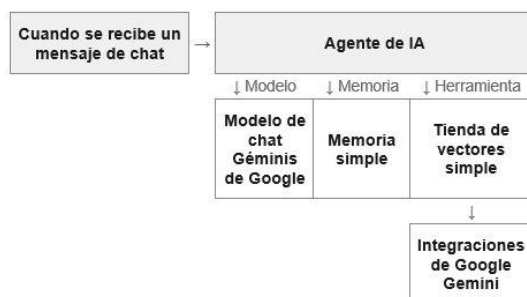
Capacidad	Qué entra	Qué procesa	Qué devuelve
C1 — Análisis	El usuario escribe 'analiza la política'	El agente busca en los documentos	Informe estructurado con áreas cubiertas, nivel de cobertura y

		indexados y Gemini analiza el contenido	áreas ausentes según normativa
C2 — Gap Analysis	El usuario pide un análisis de brechas	Compara la política de MIDTECH con GDPR, ISO 27001 y ENS	Tabla de incumplimientos ordenada por criticidad con referencia normativa exacta
C3 — Auditoría	Pregunta de cumplimiento en lenguaje natural	Recupera fragmentos relevantes y Gemini responde citando fuentes	Respuesta con cita literal de la política, artículo normativo y conclusión de cumplimiento
C4 — Mejoras	El usuario pide propuestas de mejora	Identifica carencias en los documentos y genera plan de acción	Lista ordenada por prioridad y esfuerzo con normativa que justifica cada mejora

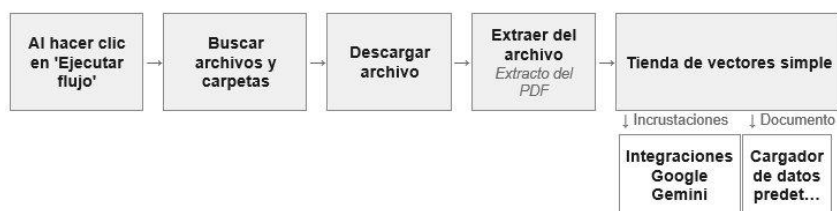
1.6 Diagrama visual del flujo

1.4 Diagrama visual del flujo

Flujo 1 — Chat con el usuario:



Flujo 2 — Carga e indexación de documentos:



El diagrama muestra los dos flujos construidos en n8n. El Flujo 1 gestiona el chat: el usuario envía un mensaje, el Agente de IA consulta la Tienda de vectores para recuperar fragmentos relevantes, usa la Memoria simple para mantener el contexto, y Gemini genera la respuesta. El Flujo 2 se ejecuta una vez para indexar: descarga cada PDF de Google Drive, extrae el texto, genera embeddings con Gemini Embeddings y los almacena en la Tienda de vectores.

Fase 2 — Base de conocimiento (RAG)

2.1 Documentos indexados

- CELEX_32016R0679_ES_TXT.pdf — GDPR
- ISO27001_2022.pdf — ISO 27001
- BOE-A-2022-7191-consolidado.pdf — ENS
- MIDTECH Política 18-05-2026.pdf — Política de seguridad de MIDTECH S.A.

2.2 Proceso de indexación

He ejecutado el Flujo 2 de n8n una vez. El flujo descarga los archivos de Google Drive, extrae el texto de cada PDF, genera embeddings con gemini-embedding-001 y los almacena en la tienda de vectores simple.

2.3 Evidencia de funcionamiento del RAG

Las respuestas del asistente en la Fase 3 demuestran que el RAG funciona: el asistente cita secciones concretas de la política de MIDTECH (4.1.2, 4.1.3, 4.1.4) y artículos exactos de la normativa (GDPR Art. 32, ISO 27001 Anexo A), lo que solo es posible si los documentos han sido indexados y recuperados correctamente por el sistema RAG.

Fase 3 — Construcción del asistente

3.1 Capacidad 1 — Análisis de la política de seguridad de MIDTECH

Pregunta formulada al asistente

Analiza la política de seguridad de MIDTECH

Respuesta del asistente

(a) Áreas cubiertas

Acuerdo general: "La presente Política de Seguridad de la Información (PSI) establece los principios, responsabilidades y controles básicos que deben regir el tratamiento de la información en MIDTECH SA con el objetivo de proteger la confidencialidad, integridad y disponibilidad de los activos de información."

Control de Acceso (Sección 3): "El acceso a los sistemas de información de MIDTECH SA se otorga en función del principio de mínimo privilegio. Todo acceso debe estar previamente autorizado..."

Seguridad Física y del Entorno (Sección 4): "Las instalaciones de MIDTECH SA cuentan con control de acceso físico mediante tarjeta de proximidad. El centro de datos de Zaragoza dispone de sistemas de detección de incendios y climatización controlada."

Gestión de incidentes de seguridad (Sección 7): "MIDTECH SA dispone de un procedimiento básico de notificación de incidentes de seguridad. Cualquier empleado que detecte un incidente debe notificarlo al departamento de TI..."

Continuidad del negocio y copias de seguridad (Sección 8): "MIDTECH SA realiza copias de seguridad diarias de los servidores de producción."

Relación con proveedores y terceros (Sección 9): "MIDTECH SA trabaja con proveedores externos que pueden tener acceso a sistemas o datos de la organización."

Concienciación y formación (Sección 10): "MIDTECH SA realiza una sesión de formación en seguridad de la información para los nuevos empleados en el momento de su incorporación."

Protección de datos personales (Sección 11): "MIDTECH SA trata datos personales de pacientes, empleados y clientes en el marco de su actividad. La empresa ha designado un Responsable de Privacidad interno para supervisar el cumplimiento normativo."

(b) Nivel de cobertura

Nivel de cobertura: Parcial

El documento sienta unas bases correctas y reconoce expresamente su aplicación sobre sistemas críticos (gestión clínica, ERP, laboratorio), pero su madurez es baja. Identifica en su propio texto numerosas "limitaciones" que reflejan que las medidas aplicadas no son suficientes para el volumen y el riesgo de una empresa biotecnológica e industrial con datos de salud (1.524 millones de euros de facturación). Faltan planes de continuidad formales, externalización de respaldos, sistemas de autenticación fuerte y una gestión madura del riesgo en la cadena de suministro.

(c) Áreas ausentes

Según ISO 27001 y ENS:

— Autenticación y Accesos: Falta la implantación generalizada de MFA, actualmente "en evaluación".

— Continuidad y Resiliencia: No existe BCP ni DRP formalmente documentados. Las copias de seguridad carecen de almacenamiento externo y no se realizan pruebas de restauración periódicas.

— Gestión de Incidentes: No existe clasificación formal de incidentes por severidad (crítico, alto, medio, bajo).

— Cadena de Suministro: Faltan procesos formales de evaluación de proveedores, cláusulas de seguridad en contratos y auditorías de accesos a terceros.

— Capacitación: Ausencia de plan de formación continua; sin simulacros (phishing) ni registro documentado del personal formado.

Según GDPR:

— DPO: La política indica que "no se ha designado un Delegado de Protección de Datos (DPO) externo o independiente", siendo obligatorio al tratar datos de salud a gran escala.

— RAT: El registro es parcial ("solo para los procesos principales"), incumpliendo el Artículo 30 del GDPR.

— Notificación de Brechas: El procedimiento "no contempla de forma explícita los plazos de notificación a la Autoridad de Control". El GDPR exige notificación en máximo 72 horas.

3.2 Capacidad 2 — Gap Analysis

Pregunta formulada al asistente

Hazme un análisis de brechas de la política de MIDTECH

Respuesta del asistente

Área normativa	Carencia detectada	Criticidad	Referencia normativa
Protección de Datos (Privacidad)	MIDTECH trata datos de categoría especial (salud de pacientes), pero no ha designado un DPO independiente. Además, el Registro de Actividades de Tratamiento (RAT) es parcial e incompleto.	Alto	GDPR Art. 37 (DPO) y Art. 30 (RAT)
Continuidad de Negocio y Backups	No existe BCP ni DRP. Las copias de seguridad se almacenan en la misma sala del CPD sin almacenamiento externo y sin pruebas de restauración periódicas.	Alto	ISO 27001 Controles 5.30 y 8.13; ENS op.cont.1, op.cont.3
Gestión de Incidentes de Seguridad	El procedimiento no clasifica incidentes por severidad y no contempla el plazo de 72 horas para notificación a la Autoridad de Control ante brechas de datos de salud.	Alto	GDPR Art. 33; ISO 27001 Controles 5.24 y 5.25; ENS op.exp.7
Control de Acceso Lógico	No se ha implantado MFA de forma generalizada (solo en "evaluación presupuestaria"), a pesar de la sensibilidad de la información biomédica y corporativa.	Alto	ISO 27001 Control 5.16; ENS op.acc.5
Cadena de Suministro (Terceros)	Sin proceso formal de evaluación de proveedores. Los contratos carecen de cláusulas de seguridad y no se realizan auditorías a terceros.	Medio	ISO 27001 Controles 5.19, 5.20 y 5.21
Concienciación y Formación	Solo hay formación básica al inicio. Sin plan de formación continua, sin registros y sin simulacros prácticos (phishing).	Medio	ISO 27001 Control 6.3; ENS op.per.2

3.3 Capacidad 3 — Respuestas de auditoría

Pregunta 1 — ¿Cumplimos con el artículo 32 del RGPD?

(A) Qué dice la política de MIDTECH

"Los equipos portátiles corporativos disponen de cifrado de disco completo (BitLocker)." Sin embargo: "No se ha implantado autenticación multifactor (MFA) de forma generalizada."

Sección 8: "MIDTECH SA realiza copias de seguridad diarias de los servidores de producción. Las copias se almacenan en un servidor de respaldo ubicado en la misma sala del CPD." Limitación: "no se realizan pruebas de restauración de forma periódica."

Sobre la resiliencia (Sección 8): "No existe un Plan de Continuidad de Negocio (BCP) ni un Plan de Recuperación ante Desastres (DRP) formalmente documentados."

Anexo 1: "Evaluación de Impacto (EIPD) — No implementada — Sin ninguna EIPD realizada."

(B) Qué exige la normativa — GDPR Art. 32

Art. 32.1.b: "La capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento."

Art. 32.1.c: "La capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico."

Art. 32.1.d: "Un proceso de verificación, evaluación y valoración periódica de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento."

(C) Conclusión

Cumple parcialmente (con tendencia al incumplimiento grave). La falta de pruebas de restauración, la ausencia de almacenamiento externo para las copias y la inexistencia de BCP/DRP impiden garantizar la resiliencia y restauración rápida. La ausencia de EIPD y de MFA agravan severamente el riesgo para datos de salud.

Pregunta 2 — ¿Qué controles del Anexo A de ISO 27001 no estamos aplicando?

(A) Qué dice la política de MIDTECH

El Anexo 1 cita literalmente como ausentes o insuficientes:

"MFA — No implementar — ISO A.9.4.2 — En evaluación presupuestaria."

"Cifrado en tránsito — No documentado — ISO A.10.1.1 — Sin política formal ni protocolos mínimos."

"Plan de Continuidad (BCP/DRP) — No implementado — ISO A.17.1 — No existe documentación."

"Gestión de proveedores — No implementado — ISO A.15.1 — Sin cláusulas de seguridad en contratos."

"Revisión periódica de la política — No documentado — ISO A.18.2 — Sin constancia de última revisión."

(B) Qué exige la normativa — ISO 27001 Anexo A

A.9.4.2: proteger los sistemas de autenticación (MFA como estándar actual, controles 5.16/5.17 en versión 2022). A.10.1.1: desarrollo e implementación de una política de uso de controles criptográficos. A.15.1: mitigar riesgos de proveedores con acuerdos documentados. A.17.1: planes de contingencia para continuidad y recuperación. A.18.2: revisión de la política a intervalos planificados.

(C) Conclusión

Incumple. MIDTECH carece de la aplicación formal de estos 5 controles estratégicos. No podría obtener la certificación ISO 27001 en su estado actual: sin MFA, sin cifrado en tránsito, sin BCP/DRP y sin control formal de la cadena de suministro.

Pregunta 3 — ¿Tenemos una política de gestión de contraseñas documentada?

(A) Qué dice la política de MIDTECH

Sección 3.2 establece literalmente: "Longitud mínima de 8 caracteres. Combinación de letras mayúsculas, minúsculas y números. Cambio obligatorio cada 180 días. No se permite reutilizar las últimas 5 contraseñas."

Nota del mismo documento: "No se ha implantado autenticación multifactor (MFA) de forma generalizada. Su adopción está en evaluación para el próximo ejercicio presupuestario." Anexo 1: "Sin MFA. Longitud mínima de 8 caracteres insuficiente."

(B) Qué exige la normativa

ISO 27001 A.9.4.3: contraseñas de calidad (estándar actual: mínimo 12-14 caracteres). A.9.4.2: MFA como estándar de protección de credenciales. ENS: MFA explícitamente requerido para sistemas con datos sensibles.

(C) Conclusión

Cumple parcialmente con riesgo alto. Existe política documentada, pero sus parámetros son obsoletos e insuficientes para datos de categoría especial. MIDTECH estaría en no conformidad en cualquier auditoría de ISO 27001 o GDPR.

Pregunta 4 — ¿Cómo gestionamos los incidentes de seguridad según nuestra política?

(A) Qué dice la política de MIDTECH

Sección 7: "Cualquier empleado que detecte un incidente debe notificarlo al departamento de TI a través del correo de soporte (soporte.ti@midtech.es) o por teléfono." Proceso de 5 pasos: "1. Detección y notificación al departamento de TI. 2. Registro del incidente en el sistema de tickets. 3. Análisis y clasificación por parte del equipo de TI. 4. Aplicación de contención. 5. Cierre del ticket y comunicación al usuario afectado."

Limitaciones reconocidas: "No existe una clasificación formal de incidentes por severidad (crítico, alto, medio, bajo). El procedimiento no contempla de forma específica los plazos de notificación a la Autoridad de Control en caso de brecha de datos personales (72 horas según el GDPR). No hay un equipo de respuesta a incidentes (CSIRT) formalmente constituido." Anexo 1: "Sin severidad. Sin plazo 72h GDPR. Sin CSIRT."

(B) Qué exige la normativa

ISO 27001 A.16.1: enfoque coherente para la gestión de incidentes, con clasificación de eventos, equipo de respuesta (CSIRT) y simulacros. GDPR Art. 33: notificación a la autoridad de control competente (AEPD) a más tardar 72 horas después de tener constancia de la brecha.

(C) Conclusión

Cumple parcialmente. MIDTECH cuenta con un circuito de reporte básico, pero incumple aspectos críticos: sin clasificación de severidad, sin CSIRT formal y sin protocolo de notificación de brechas en 72h a la AEPD.

3.4 Capacidad 4 — Propuestas de mejora

Pregunta formulada al asistente

Dame propuestas de mejora para la política de MIDTECH

Respuesta del asistente

Mejora propuesta	Normativa que la justifica	Prioridad	Esfuerzo
Aumentar la longitud y complejidad de contraseñas (la política actual permite un mínimo de 8 caracteres, insuficiente para proteger accesos a datos de salud).	ISO 27001 A.9.4.3 / ENS	Alta	Bajo
Actualizar el protocolo de gestión de incidentes incluyendo clasificación formal de severidad y el plazo obligatorio de notificación	GDPR Art. 33 / ISO 27001 A.16.1.1	Alta	Bajo

de 72 horas para brechas de datos personales.			
Formalizar el cumplimiento de privacidad: designar un DPO independiente, completar el Registro de Actividades (RoPA) y realizar las EIPD omitidas para tratamientos de alto riesgo.	GDPR Art. 30, 35 y 37	Alta	Medio
Implantar Autenticación Multifactor (MFA) de forma generalizada (actualmente solo en evaluación presupuestaria).	ISO 27001 A.9.4.2 / ENS	Alta	Medio
Elaborar y documentar un Plan de Continuidad (BCP/DRP), actualmente inexistente, para garantizar la recuperación del servicio.	ISO 27001 A.17.1	Alta	Alto
Actualizar el inventario de activos de TI para incluir las herramientas y aplicaciones de software de terceros (SaaS), actualmente fuera de control.	ISO 27001 A.8.1.1	Media	Bajo
Incluir cláusulas de seguridad y confidencialidad en los contratos para formalizar la gestión con los proveedores.	ISO 27001 A.15.1	Media	Bajo
Documentar un protocolo de uso de controles criptográficos para establecer estándares mínimos en el cifrado de información en tránsito.	ISO 27001 A.10.1.1	Media	Medio
Estandarizar y auditar la seguridad física de sedes periféricas (Madrid y Barcelona), que actualmente no cuentan con el mismo nivel de control que el CPD de Zaragoza.	ISO 27001 A.11.1 / ENS	Media	Medio

Fase 4 — Entrega y demostración

4.1 Acceso al asistente

<https://proyecto-midtech.app.n8n.cloud/webhook/3426a235-152d-4bcf-a3b3-d11ab231b784/chat>

Las credenciales de acceso se entregan en documento separado a través de Scola.

4.2 Vídeo de demostración

<https://www.youtube.com/watch?v=eER5L-Yla6c>

4.3 Repositorio GitHub

<https://github.com/Ex-1217/tfc-asistente-ciberseguridad-y-compliance>

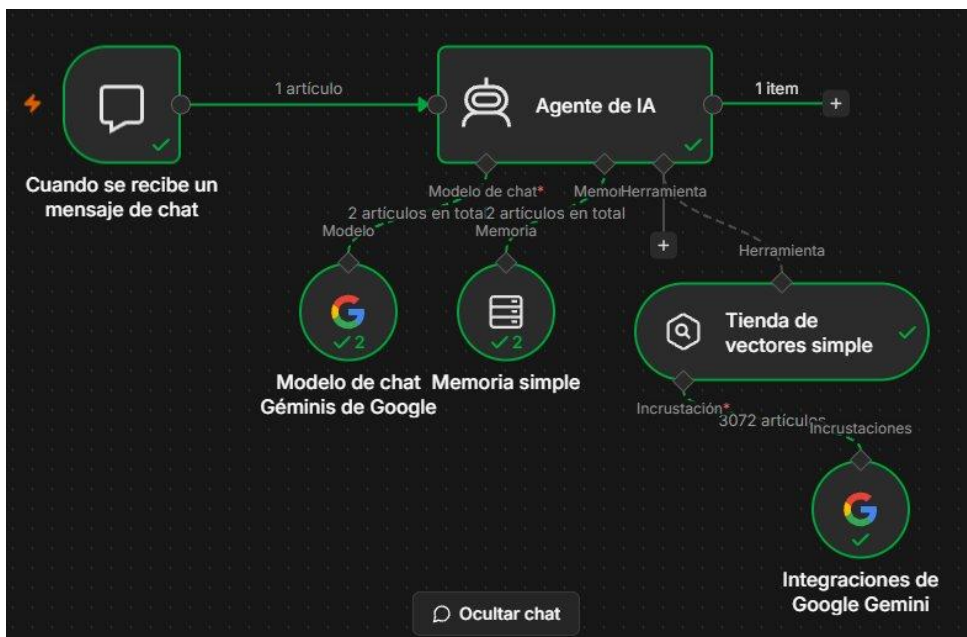
4.4 Canvas de n8n

Evidencias de funcionamiento — las cuatro capacidades

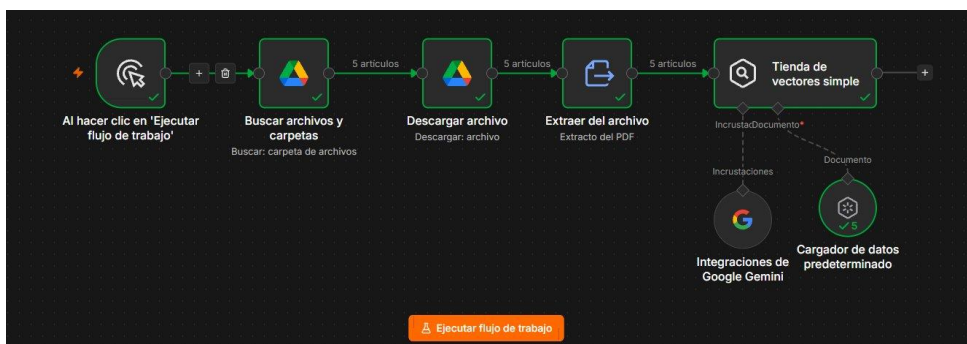
El asistente ha estado operativo durante el periodo de evaluación en la URL indicada en 4.1. La tabla siguiente resume las cuatro capacidades demostradas con las preguntas reales utilizadas y las fuentes citadas en cada respuesta.

Capacidad	Pregunta formulada	Fuentes citadas en la respuesta	Resultado
C1 — Análisis de política	Analiza la política de seguridad de MIDTECH	PSI-MIDTECH-2025-v2.1, secciones 3, 4, 7, 8, 9, 10 y 11	Informe estructurado con 3 bloques: áreas cubiertas, nivel de cobertura parcial, áreas ausentes
C2 — Gap Analysis	Hazme un análisis de brechas de la política de MIDTECH	GDPR Art. 37, 30, 33, 35; ISO 27001 Controles 5.16, 5.24, 5.30, 6.3; ENS op.cont.1, op.acc.5	Tabla con 6 incumplimientos ordenados por criticidad: 4 altos, 2 medios
C3 — Auditoría	¿Cumplimos con el artículo 32 del GDPR?	PSI sección 3.2 y Anexo 1; GDPR Art. 32.1.b, 32.1.c y 32.1.d	Cumplimiento parcial. Cita literal de política + artículo normativo + conclusión justificada
C4 — Propuestas de mejora	Dame propuestas de mejora para la política de MIDTECH	GDPR Art. 37, 33, 35; ISO 27001 Controles 5.16, 5.24, 5.30; ENS op.acc.5	8 propuestas ordenadas por prioridad y esfuerzo con referencia normativa exacta
Prueba de scope	¿Cuál es la capital de Francia?	Ninguna (pregunta fuera del ámbito del asistente)	Rechazo correcto: "Solo estoy preparado para responder preguntas sobre ciberseguridad y cumplimiento de MIDTECH SA."

Flujo 1 — Chat con el usuario:



Flujo 2 — Indexación de documentos:



Anexo — Documentación de prompts

Nota: el asistente funciona con un único prompt de sistema que cubre las cuatro capacidades. Se presenta aquí en cuatro bloques separados (C1, C2, C3, C4) para facilitar la evaluación por capacidad, tal como exigen las instrucciones del TFC. El prompt real configurado en el Agente de IA de n8n es el descrito en C3 (Auditoría), que incluye las instrucciones para analizar la política, detectar incumplimientos, responder preguntas y proponer mejoras según los documentos indexados.

Prompt C1 — Análisis de política

Capacidad	C1
Herramienta / Modelo	n8n Cloud Google Gemini Pro (gemini-pro-latest)
Objetivo del prompt	Que el asistente produzca un informe estructurado citando texto literal de la política de MIDTECH.
Texto del prompt de sistema	Eres un asistente experto en ciberseguridad y compliance para MIDTECH S.A. Cuando el usuario pida analizar la política de seguridad, genera un informe en tres bloques: (1) Áreas cubiertas con cita literal y sección. (2) Nivel de cobertura: completo, parcial o no documentado. (3) Áreas que exige la normativa (GDPR, ISO 27001, ENS) y no aparecen en la política. No inventes nada. Si no lo encuentras en el documento, dilo.
Ejemplo de entrada	Analiza la política de seguridad de MIDTECH
Ejemplo de salida obtenida	Informe con áreas cubiertas citando secciones 4.1.1 a 4.2, nivel de cobertura completo en el marco general, y áreas ausentes en GDPR Art. 25 y 30, ISO 27001 A.8.1.1 y A.10.1.1, y ENS categorización de sistemas.
Valoración crítica	El resultado fue específico para MIDTECH y citó secciones concretas. Como limitación, el modelo no siempre cita el texto literal exacto sino que lo parafrasea.

Prompt C2 — Gap Analysis

Capacidad	C2
Herramienta / Modelo	n8n Cloud Google Gemini Pro (gemini-pro-latest)
Objetivo del prompt	Que el asistente compare la política con las normativas y devuelva los incumplimientos por criticidad.
Texto del prompt de sistema	Eres un asistente experto en ciberseguridad y compliance para MIDTECH S.A. Cuando el usuario pida un gap analysis, compara la política interna con GDPR, ISO 27001 y ENS. Por cada incumplimiento devuelve: área normativa, descripción concreta de lo que falta, criticidad (Alto/Medio/Bajo) y referencia exacta. Ordena de mayor a menor criticidad. Basa todo en los documentos indexados.
Ejemplo de entrada	Hazme un gap analysis de la política de MIDTECH
Ejemplo de salida obtenida	Tabla con 9 incumplimientos: 2 criticidad alta (GDPR Art. 32 y Art. 25), 6 criticidad media y 1 baja, con referencias exactas a ISO 27001 y ENS.

Valoración crítica	La tabla es clara y útil. El punto débil es que algunos incumplimientos son deducciones del modelo, no citas literales de la política.
---------------------------	--

Prompt C3 — Auditoría

Capacidad	C3
Herramienta / Modelo	n8n Cloud Google Gemini Pro (gemini-pro-latest)
Objetivo del prompt	Que el asistente responda citando siempre la política de MIDTECH y la normativa.
Texto del prompt de sistema	Eres un asistente experto en ciberseguridad y compliance para MIDTECH S.A. Tienes acceso a los documentos indexados: GDPR, ISO 27001, ENS y la Política de Seguridad de MIDTECH. Usa SIEMPRE esos documentos para responder. Para cada pregunta responde con: (A) Qué dice la política de MIDTECH (cita literal + sección). (B) Qué exige la normativa (artículo/control exacto). (C) Conclusión: cumple / cumple parcialmente / incumple. REGLA ABSOLUTA: nunca respondas sin citar los documentos.
Ejemplo de entrada	¿Cumple MIDTECH con el artículo 32 del GDPR?
Ejemplo de salida obtenida	Respuesta citando secciones 4.1.2, 4.1.3 y 4.1.4 de la política y el Artículo 32 del GDPR. Conclusión: cumplimiento parcial por falta de detalle en seudonimización y evaluación continua.
Valoración crítica	Es el prompt que mejor ha funcionado. La respuesta es concreta, cita política interna y normativa, y la conclusión está justificada.

Prompt C4 — Propuestas de mejora

Capacidad	C4
Herramienta / Modelo	n8n Cloud Google Gemini Pro (gemini-pro-latest)
Objetivo del prompt	Que el asistente genere mejoras concretas priorizadas basadas en los documentos.
Texto del prompt de sistema	Eres un asistente experto en ciberseguridad y compliance para MIDTECH S.A. Cuando el usuario pida propuestas de mejora, genera una lista ordenada basada en los incumplimientos detectados en los documentos. Por cada propuesta indica: mejora concreta, normativa que la justifica, prioridad (Alta/Media/Baja) y esfuerzo (Alto/Medio/Bajo). Ordena: Alta prioridad + Bajo esfuerzo primero.
Ejemplo de entrada	Dame propuestas de mejora para la política de MIDTECH
Ejemplo de salida obtenida	8 propuestas ordenadas: las tres de prioridad alta son cifrado/seudonimización (GDPR Art. 32), protección de datos por diseño (GDPR Art. 25) y registros de actividades (GDPR Art. 30).

Valoración crítica

Propuestas concretas justificadas con artículos exactos. La ordenación por prioridad y esfuerzo es útil para un plan de acción real.

Reflexión final

Qué funciona

El asistente funciona y responde a las cuatro capacidades previstas. Cuando le preguntas algo sobre la política de MIDTECH o sobre la normativa, busca en los documentos cargados y te da una respuesta concreta citando la sección o el artículo exacto, no una respuesta genérica de relleno. También sabe cuándo no debe responder: al preguntarle “¿Cuál es la capital de Francia?” el asistente contestó literalmente “Solo estoy preparado para responder preguntas sobre ciberseguridad y cumplimiento de MIDTECH SA”, rechazando correctamente una pregunta fuera de su ámbito. Eso demuestra que el prompt está bien definido y el sistema hace exactamente lo que se le ha pedido.

Limitaciones

El mayor problema ha sido que tardé dos semanas en conseguir que el asistente funcionara correctamente. Durante ese tiempo, el límite de peticiones de la API gratuita de Gemini me obligó a cambiar de clave continuamente y finalmente a pasarme al plan de pago para poder avanzar. Además, cada vez que el asistente se reiniciaba por inestabilidad de la plataforma o por caducidad del plan, los documentos dejaban de estar disponibles y tenía que volver a indexarlos y ejecutar el flujo de carga desde cero antes de poder usar el chat. Esto supuso una pérdida de tiempo considerable a lo largo de todo el proyecto.

Qué mejoraría con más tiempo

Lo primero sería buscar una solución para que los documentos no se pierdan cada vez que se reinicia el sistema, usando algún almacenamiento externo que no dependa del plan gratuito. También mejoraría la estabilidad del entorno de pruebas para no perder tiempo reindexando y volviendo a configurar el asistente desde cero cada vez.

